



A hálózati határvédelem eszközei

Kovács Bálint

Miről lesz szó?

- A hálózati határvédelem értelmezése
- Hálózati alapfogalmak
- Tűzfal típusok
- Határvédelmi technológiák
- Speciális határvédelmi megoldások
- Kérdések és válaszok

Mi a biztonság?

- Kedvező állapot
  - Nincsenek fenyegetések
  - Nem is valószínű, de nem zárható ki
- Maradék kockázat
  - Mindig van
  - Nem mindegy, hogy ismert-e
- Folyamat és nem termék
- Biztonság menedzsment: az állapot fenntartás folyamata

Az IT biztonság elemei

•Az IT biztonsági elemei:

–**Érték**: Bármi, ami a szervezet számára jelentőséggel bír (adatok, tudás, védjegy, receptek, eljárások, know-how stb).

–**Fenyegetés**: Olyan negatív esemény, amelynek esetleges bekövetkezése veszteséget okozna.

–**Sérülékenység**: A fenyegetettség bekövetkezését lehetővé tevő hiba.

–**Ellenintézkedések**: Minden olyan eszköz, tevékenység, amely az fenyegetések minimalizálását szolgálja.

–**Kompromisszumok**: Minden intézkedés, védelmi eszköz hordoz magával valamilyen hátrányt.

BALASYS

Az információ tulajdonságai

- **Bizalmasság**: az információ megtekintésének korlátozása
- **Sértetlenség**: az objektum védelme nem kívánt módosítás ellen
- **Hitelesség**: az információ forrásának hiteles megjelölése
- **Rendelkezésre állás**: az információ elérhetősége a kívánt időben
- **Letagadhatatlanság**: az információ forrásának hiteles megőrzése a jövőben

Ellenintézkedések típusai

- Ellenintézkedések típusai (Control intézkedések):
  - **Preventív**: megelőző intézkedések
  - **Detektív**: érzékelő intézkedések (megfigyelés)
  - **Korrektív**: korrigáló intézkedések

IT biztonsági eszközök

- **Adminisztratív**, pl. belső szabályzás;
- **Fizikai**, pl. zárak, beléptető rendszerek, kamerák;
- **Logikai**, pl. szoftveres és hardveres megvalósítások;

Mit értünk hálózati határvédelem alatt?

- Bejövő és kimenő hálózati forgalom monitorozása és szabályozása előre meghatározott biztonsági szabályok alapján
- Tipikusan különböző biztonsági szintű hálózatok közötti elválasztást valósít meg (pl a biztonságosnak tekintett belső hálózat és az internet)
- Logikai kontroll
- Preventív és detektív kontroll
- Olyan ellenintézkedés, ami az érték elérhetőségének fenntartása mellett a fenyegetések és sérülékenységek számát minimalizálja

BALASYS

Az IT biztonság tervezésének lépései

- A tervezés során felmerülő kérdések (Beyond Fear, Bruce Schneier):
  - Milyen értéket védünk?
  - Milyen kockázati tényezők vannak jelen?
  - A megoldás mennyire hatékonyan csökkenti a kockázatot?
  - Milyen új kockázatot jelent a megoldás?
  - Milyen költségeket és kompromisszumokat jelent a megoldás bevezetése?

A hálózati határvédelem eszközei

- Szabályzatok, eljárásrendek (IBSZ)
- Házirend (policy) karbantartás és a hozzájuk tartozó folyamatok
- Autentikációs adatbázis karbantartása
- Hibajavítás (security patch, nem új verzió telepítés!)
- Monitorozás
- Naplógyűjtés és elemzés (on-line és periodikus)

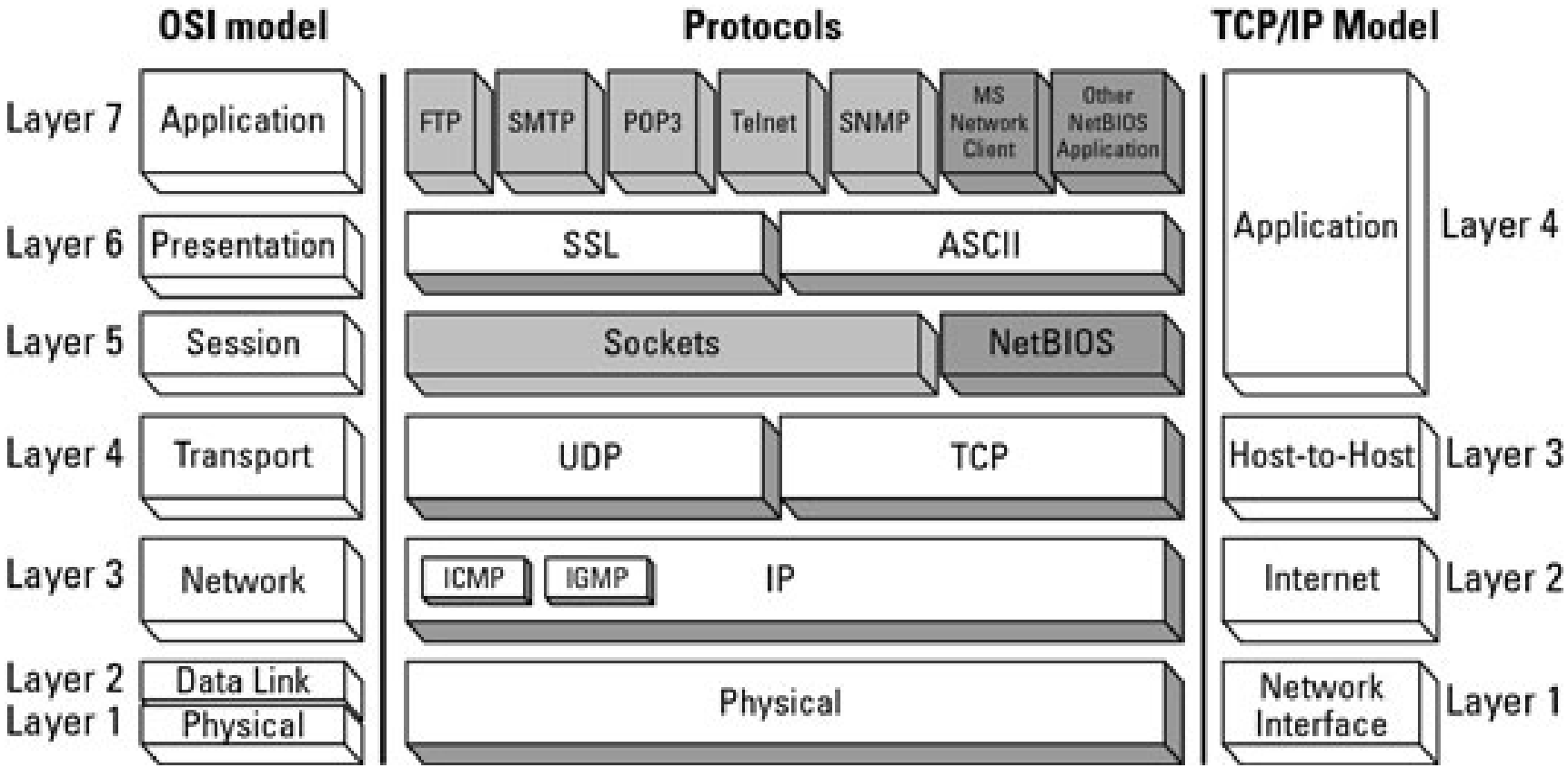
Kontrollok a hálózati határvédelemben

BALASYS

Hálózati alapfogalmak

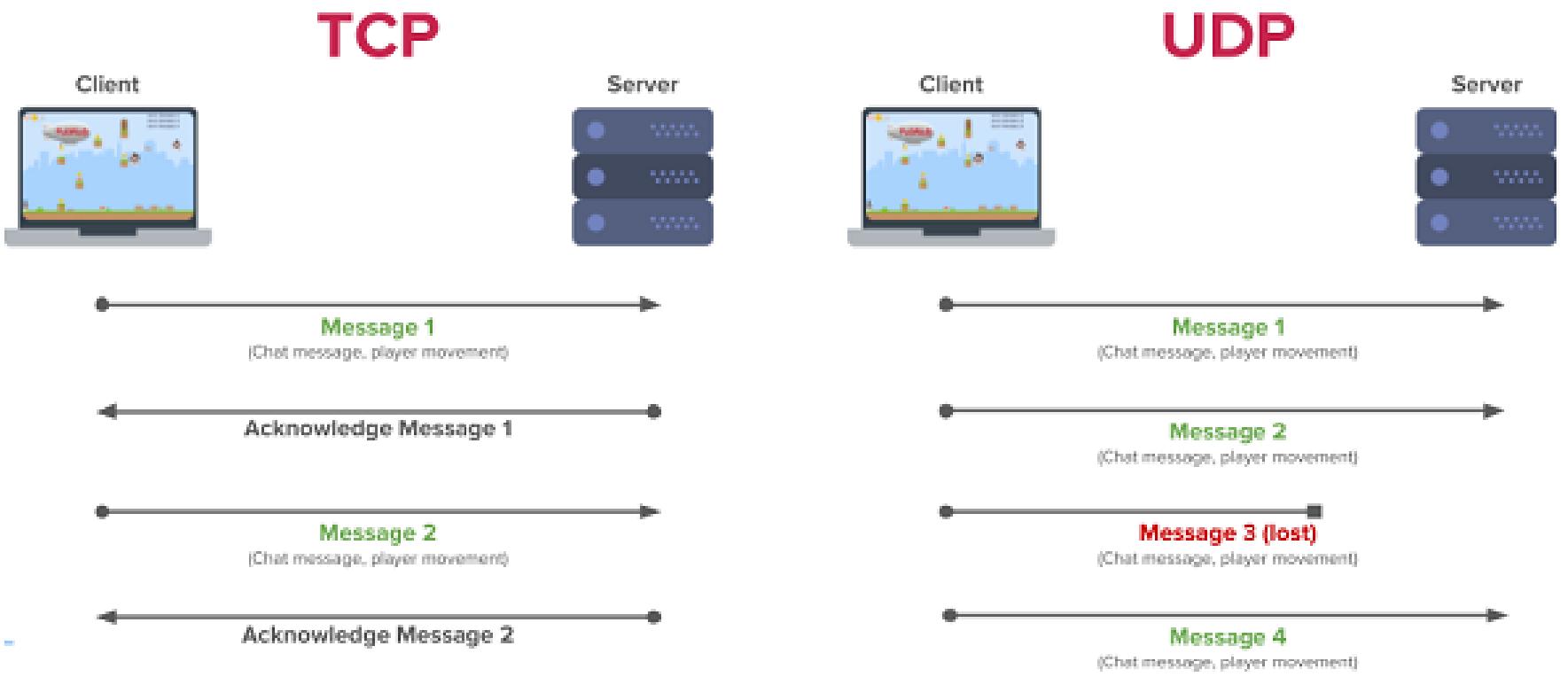
- ISO/OSI modell
- TCP vs UDP
- Hogy néz ki egy kommunikáció

ISO/OSI layer-ek és protokollok



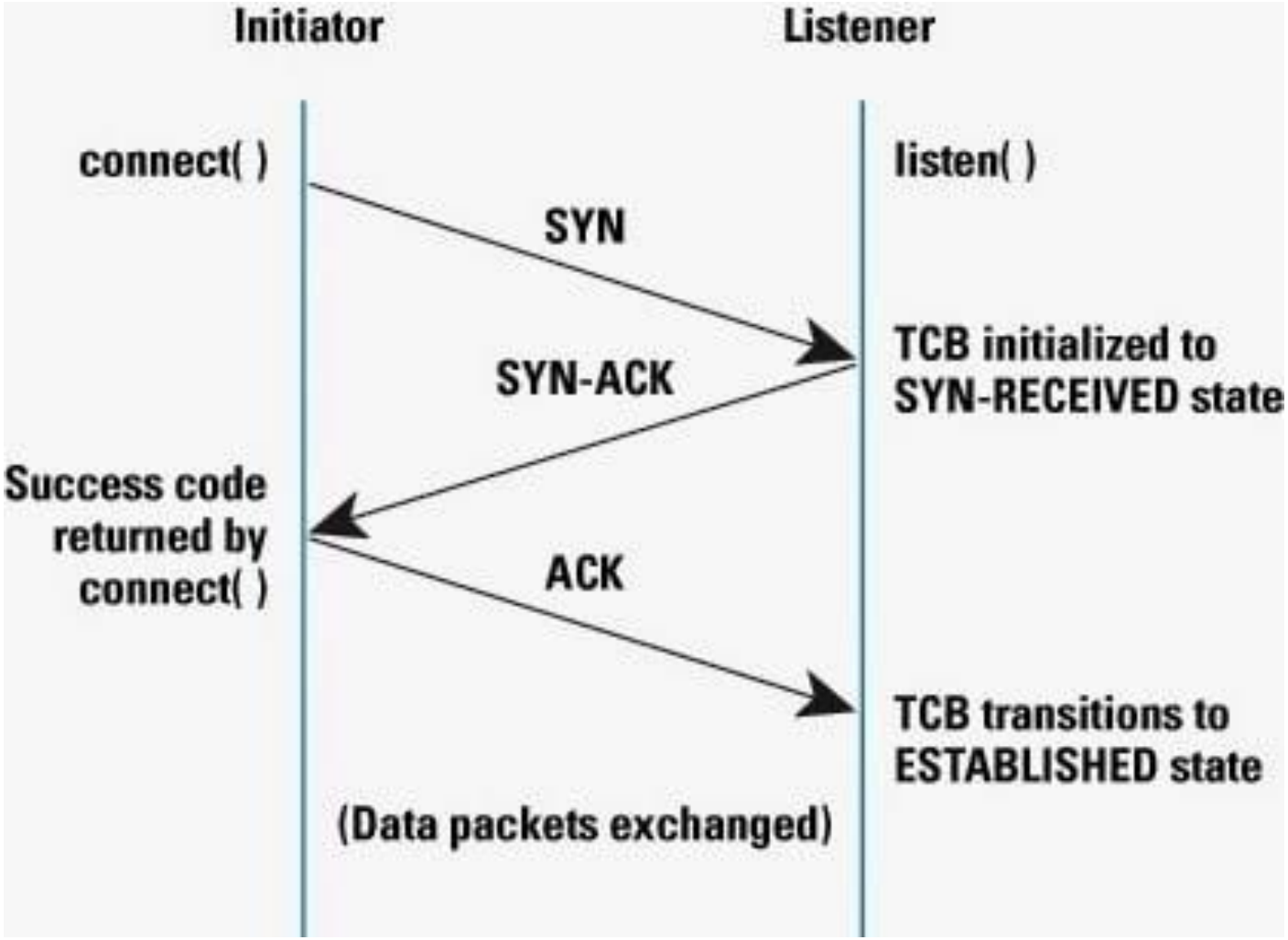
BALASYS

TCP vs UDP

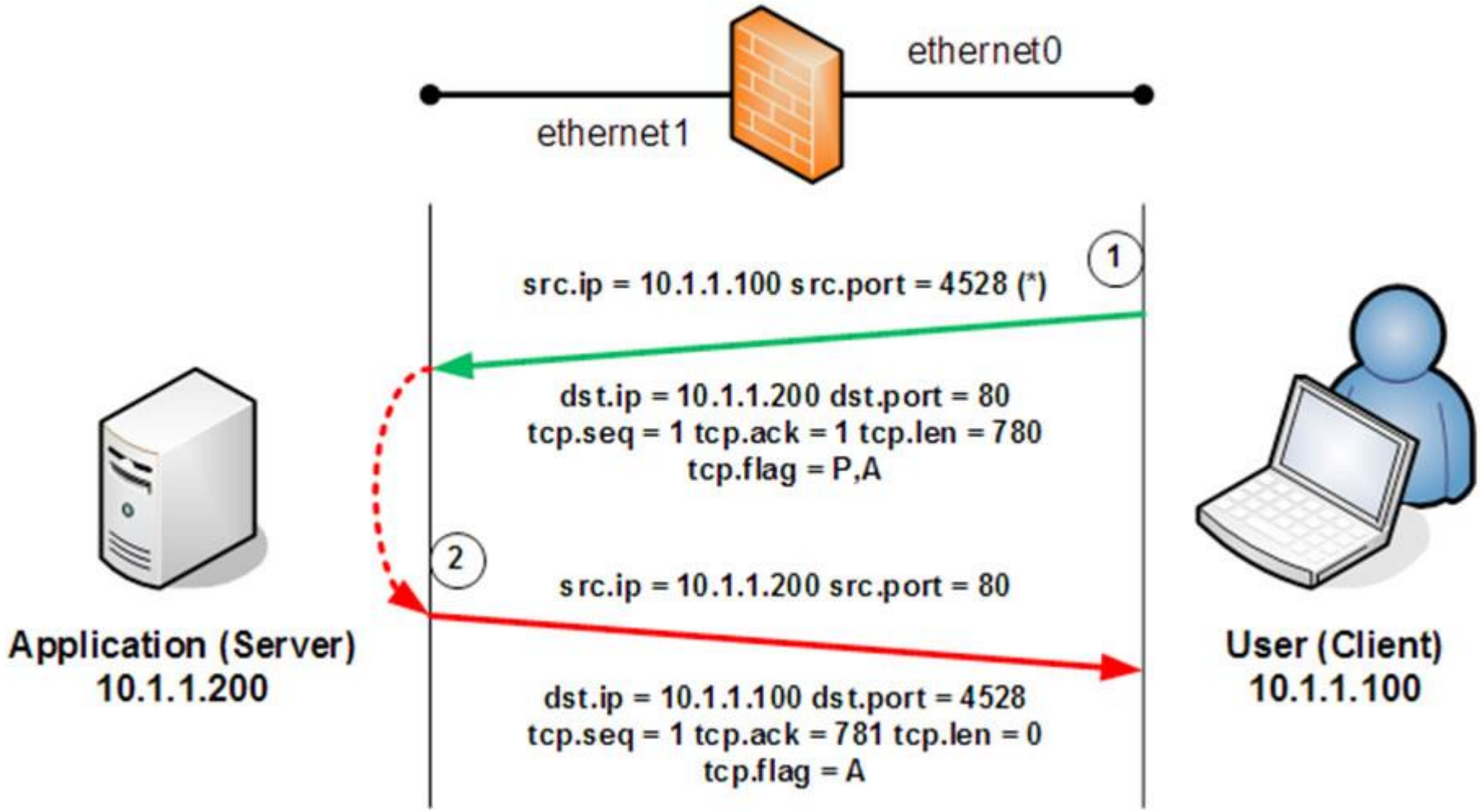


BALASYS

TCP 3-way handshake



Packet flow routing megtartással



BALASYS

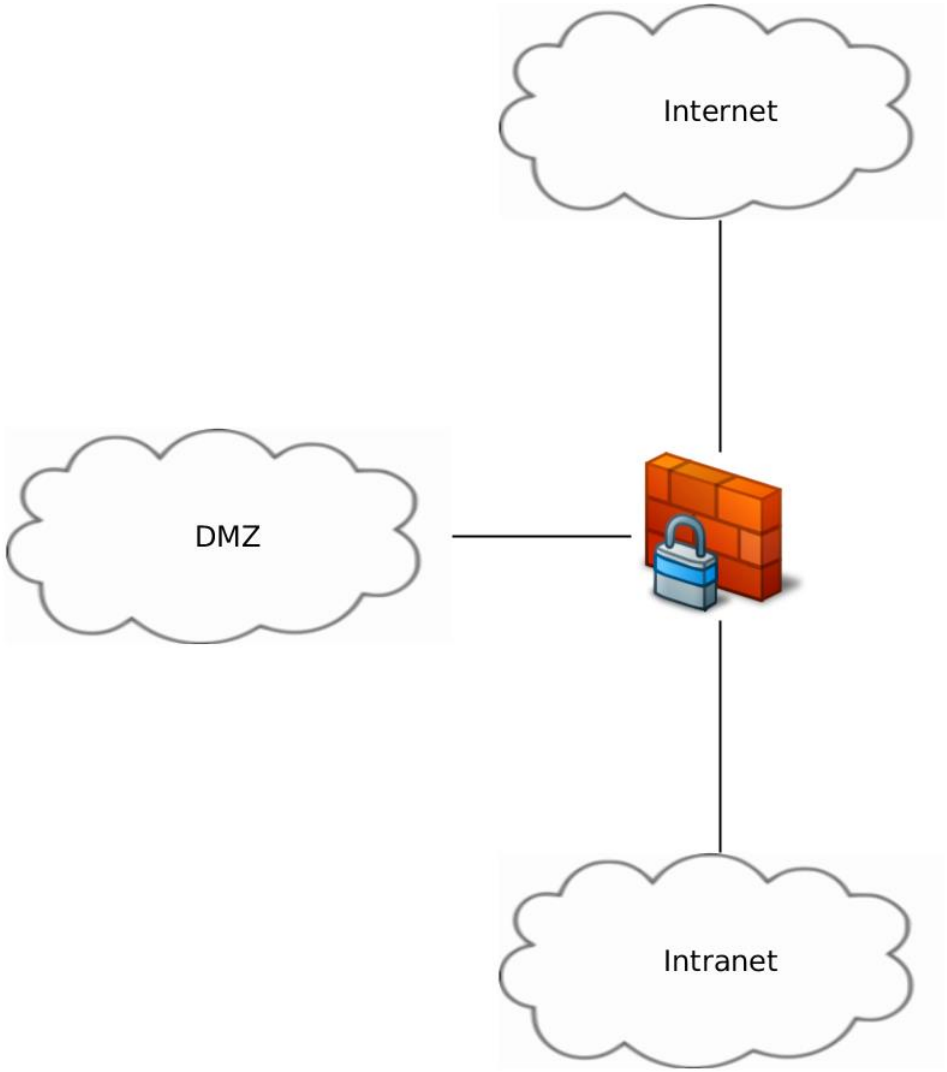
Tűzfalak típusai

- Routing megtartása:
  - Packet Filter
  - Stateful Packet Filter
  - Transzparens proxy
  - Moduláris, transzparens proxy
- Routing nélkül:
  - Bastion host
  - Proxy
  - SOCKS

Csomagszűrők

- **Működési elv**: A bejövő csomagokat tulajdonságaik alapján elfogad (továbbít, routingot végez), elvet vagy eldob illetve naplóz
- **Döntés alapja**: A csomagok forrása és célja (port és IP), bizonyos flag-ek. Ezért a szabályok csak a csomagokra vonatkoznak (Packet Filter).
  - Működési réteg: IP és transzport
- **Megvalósítás**: Minta illesztés

Routing tartó tűzfalak



BALASYS

A házirend tárolása

•A házirend (policy vagy szabályrendszer) tárolására szolgáló leggyakoribb eszköz, a hozzáférési lista (ACL - Acces Control List):

–A minta (pattern) feladata a cél (döntés) kiválasztása;

–A szabály feladata az illeszkedő (packet) sorsának eldöntése (policy verdict):

•Engedélyezés vagy tiltás;

•Ugrás másik szabályra;

•Naplózás és ugrás másik szabályra;

–Az ACL-ek feldolgozása általában az első illeszkedésig tart, ezért a számít sorrend (specifikus szabályok előre, átfogók a lista végére).

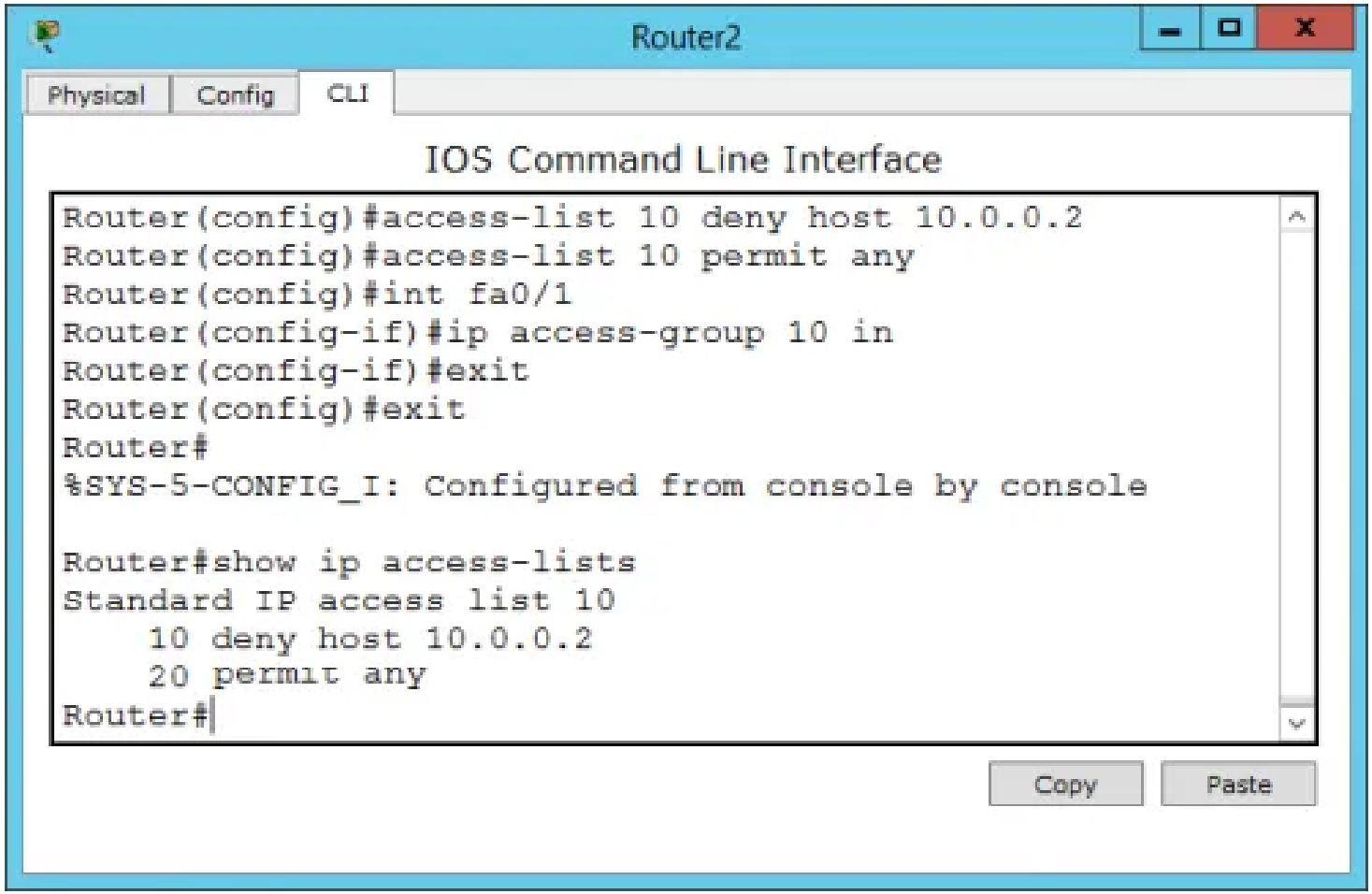
BALASYS

A házirend tárolása

	Source IP	Dest. IP	Source Port	Dest. Port	Action
1	192.168.21.0	--	--	--	deny
2	--	--	--	23	deny
3	--	192.168.21.3	--	--	deny
4	--	192.168.21.0	--	>1023	Allow

Sample Packet Filter Firewall Rule

A házirend tárolása



BALASYS

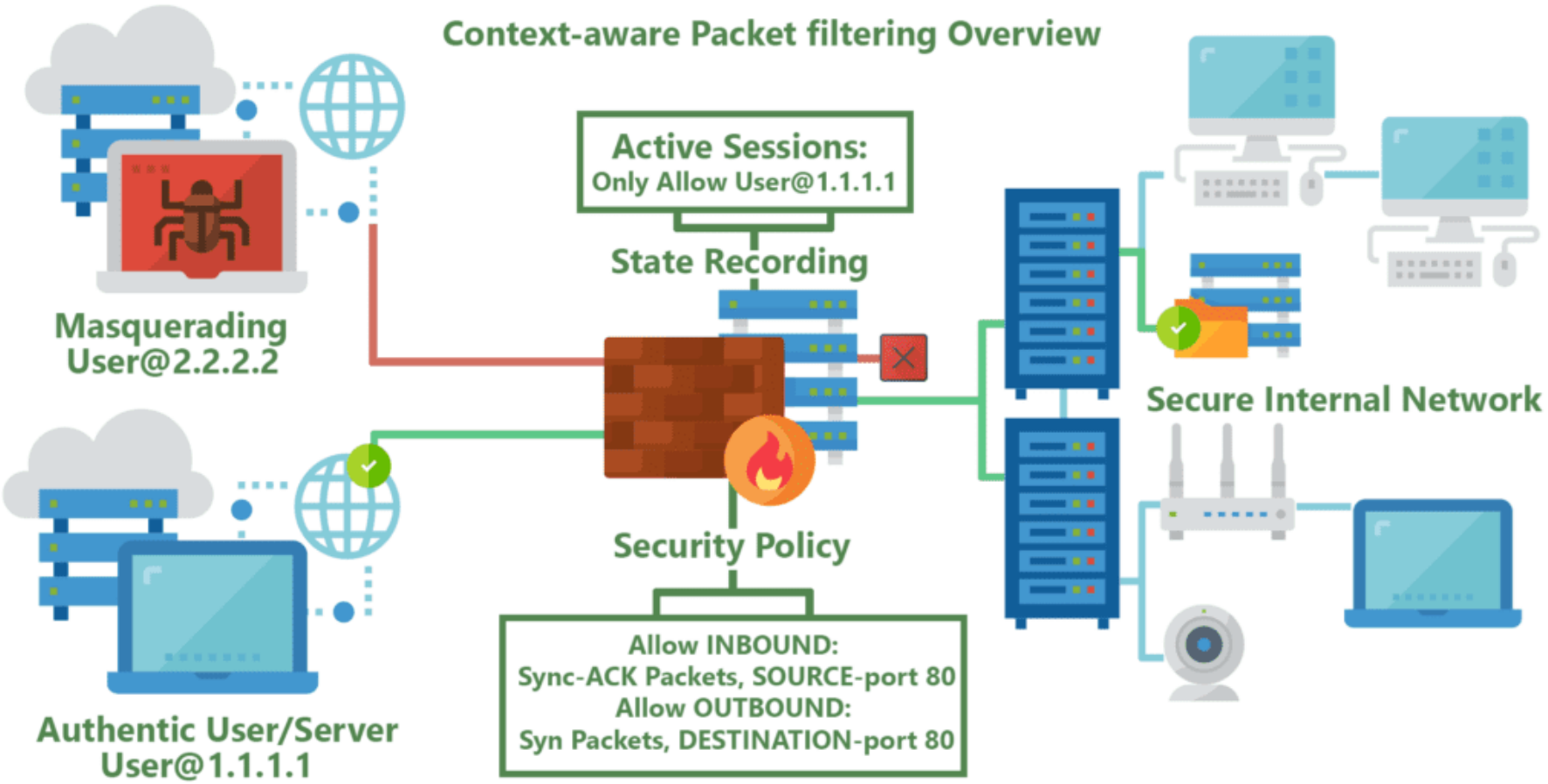
Csomagszűrő routerek értékelése

- **Előnyök**:
  - –gyors
  - –egyszerűen kezelhető szabályrendszer
- **Hátrányok**:
  - –az alkalmazás szintre nem lát
  - –többcsatornás protokollok kezelése nem megvalósítható
  - –sok szabály szükséges (válasz packetek kezelése)
- **Ismeretlen elemek kezelése:**
  - –Az ismeretlen elemeket szűrés nélkül engedik át.

Állapot tartó csomagszűrők

- **Működési elv**: A bejövő csomagokat tulajdonságaik alapján elfogad, továbbít vagy eldob.
- **Döntés alapja**: A teljes TCP és IP rétegek, (forrás, cél port és IP, seq és ack, csomagok sorrend illetve helye) tehát a kapcsolatok (Ezért állapot tartó – Stateful Packet Filter - SPF).
- **Megvalósítás**: Mintaillesztés és elemzés
- **Többcsatornás protokollok kezelése**: Valamilyen modul segítségével felismeri az alkalmazás szintből, hogy hová kell nyitni a további kapcsolatot, majd azt RELATED-nek jelöli.

Állapot tartó csomagszűrők



BALASYS

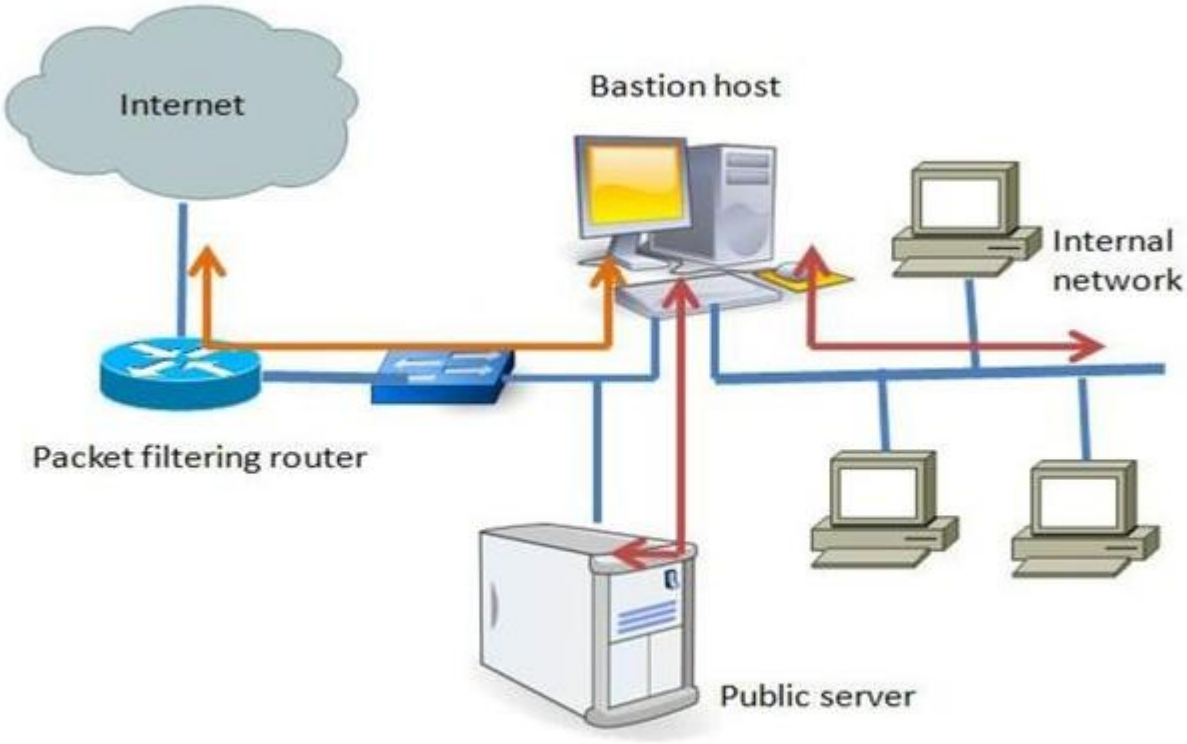
Állapot tartó értékelése

- **Előnyök**:
  - –gyors
  - –kevesebb szabály (nem kell kezelni a válaszokat)
- **Hátrányok**:
  - –alkalmazás szintre nem lát
  - –többcsatornás protokollok kezelése nehezen megvalósítható
- **Ismeretlen elemek kezelése:**
  - –Az ismeretlen elemeket szűrés nélkül engedik át.
- **Modern alkalmazása:**
  - –Datacenter tűzfalak, Felhős security group-ok

Bastion hostok

- **Működési elv**: A több hálózathoz csatlakozó (dual home vagy multi home) hoszton a bejelentkezett felhasználók szolgáltatásokat vehetnek igénybe (kombinálható csomagszűréssel).
- **Döntés alapja**: A felhasználók autenikációján alapszik.

Bastion hostok



Screened host firewall (Dual-homed bastion host)

BALASYS

Bastion hostok értékelése

- **Előnyök:**
  - –Felhasználói autentikáció általában van
  - –A kliens alkalmazás ellenőrizhető, kézben tartható
- **Hátrányok**:
  - –Elavult, de felhasználói szolgáltatásokra újra népszerű
  - –nehezen karbantartható (pl. eltérő verziók felhasználónként)
  - –erőforrás igényes
  - –a felhasználó potenciális veszélyforrást jelent
  - –az alkalmazások sérülékenységei ellen nem nyújt védelmet
- **Modern alkalmazásai:**

BALASYS

SOCKS tűzfalak

•**Működési elv**: Egy speciális, a kliensre telepített alkalmazás elveszi a kapcsolatot az operációs rendszertől és a tűzfalnak adja át.

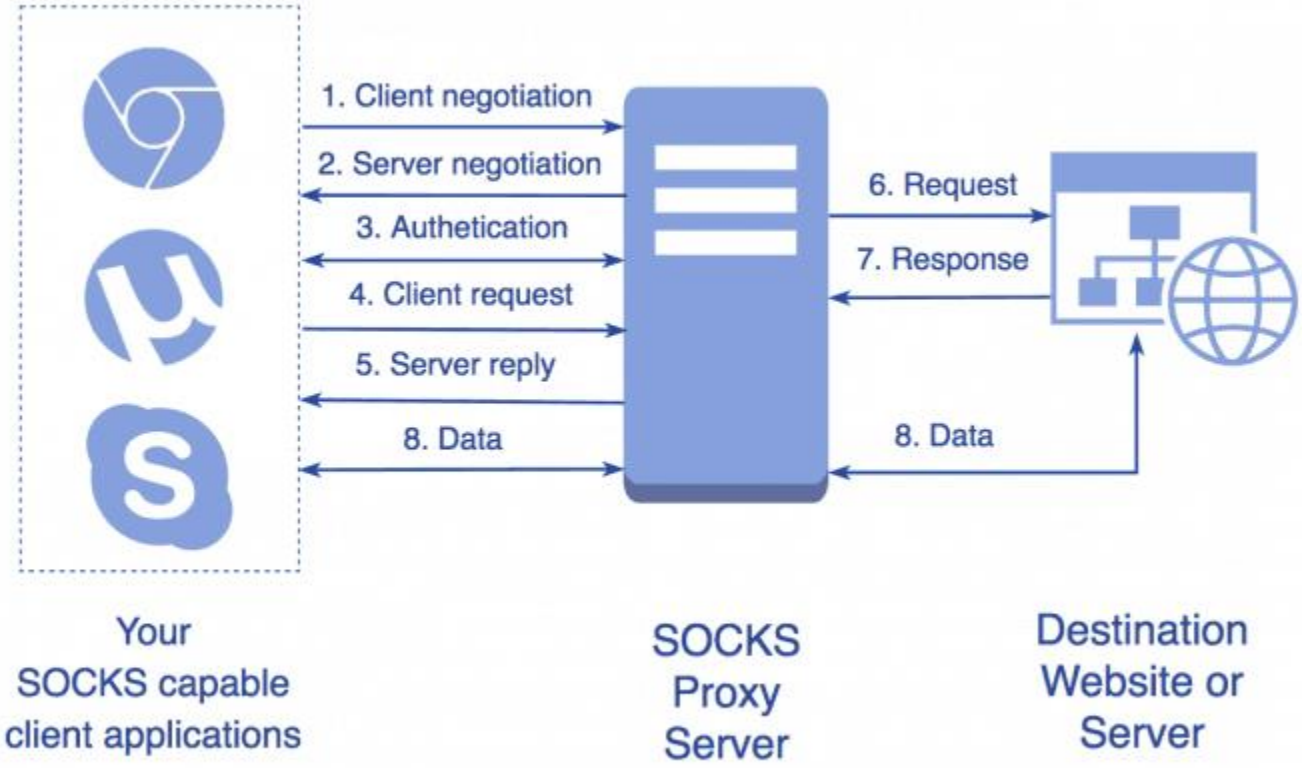
–Kicseréli az API hívásokat (beépül az alkalmazás és a TCP réteg közé, fixen a SOCKS szerverhez kapcsolódik) bár létezik olyan alkalmazás ami natívan beszéli a protokollt.

–Csak kliens védelemre alkalmas (a SOCKS proxy szerver oldalán csak 1 kapcsolat lehet, tehát nem tud sok klienst kiszolgálni.

•**Döntés alapja**: A csomagok forrása és célja (port és IP) illetve megvalósítás függően az alkalmazási réteget is elemezheti.

BALASYS

SOCKS tűzfalak



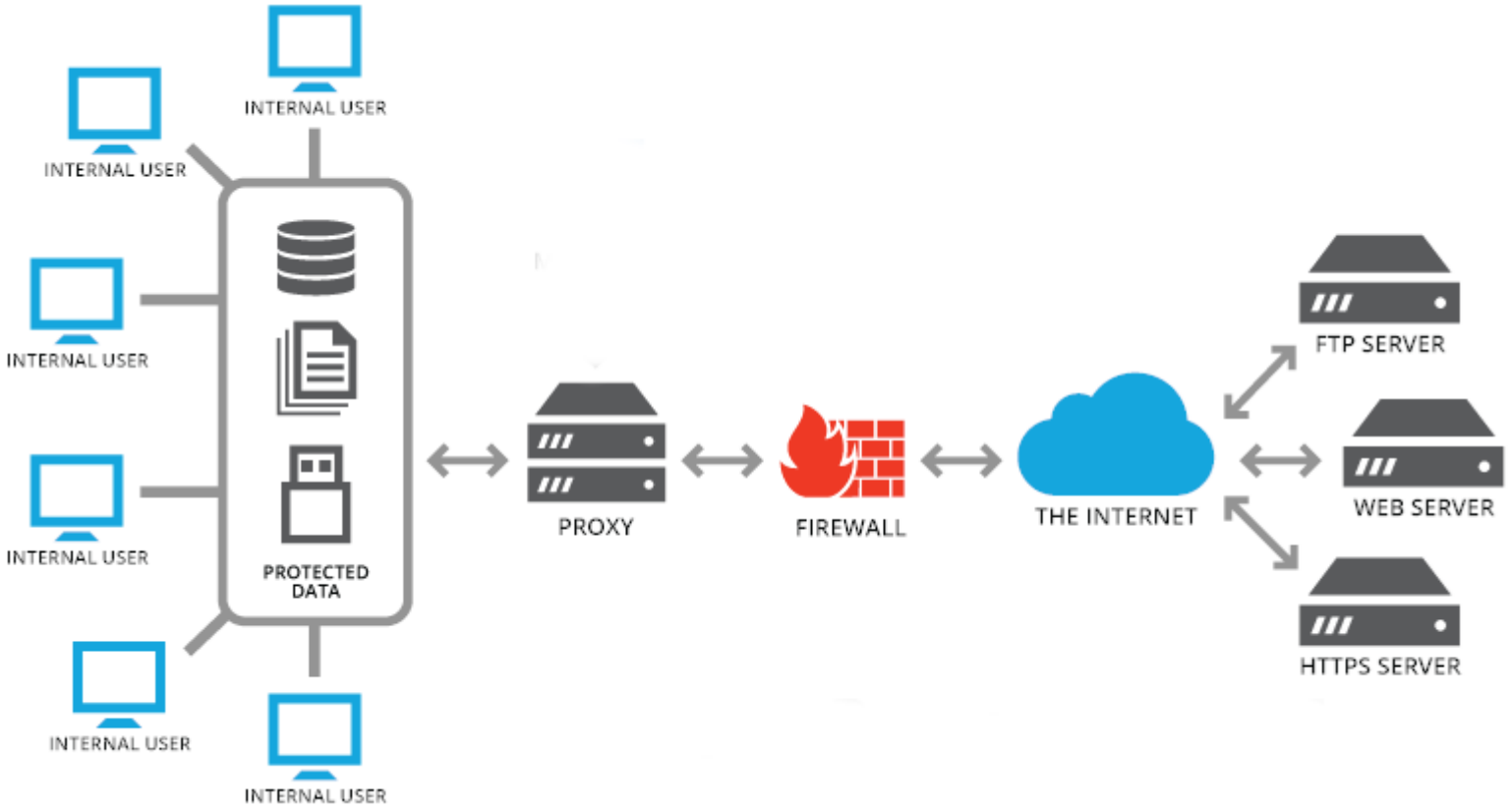
SOCKS tűzfalak értékelése

- **Előnyök**:
  - –SOCKSv5-től felhasználói authentikáció megvalósítható (pl. Kerberos SSO)
- **Hátrányok**:
  - –A kliens alkalmazások általában nem támogatják a SOCKS protokollt.
  - –Az OS-re telepíteni kell a SOCKS klienst (API csere).
  - –Szerver nem védhető.
- **Modern alkalmazása:**
  - –kihalt

Alkalmazásszintű tűzfalak

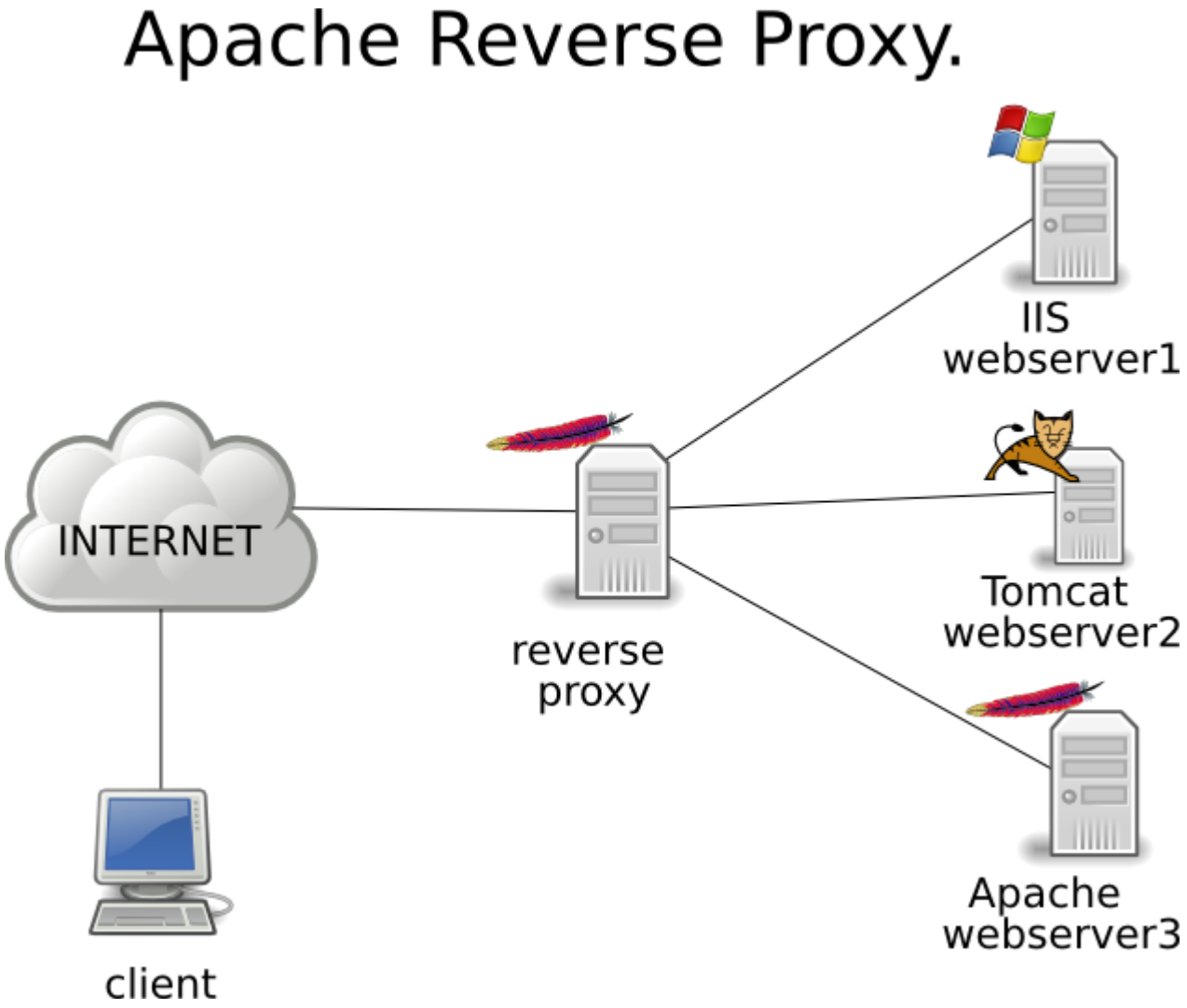
- **Működési elv**: A kliens a tűzfalon futó alkalmazással (**proxy**) tart kapcsolatot, az alkalmazás pedig a szerverrel. Fontos hogy ezek a proxyk gyorsítótár (cache) funkcióval nem rendelkeznek.
- **Döntés alapja**: Az alkalmazási réteg protokollja.
- **Megvalósítás**: Összetett. Mintaillesztés a hálózati rétegekben valamint mintaillesztés és **értelmezés** az alkalmazási rétegben. Az értelmezés mélysége függ a megvalósítástól.

Proxy tűzfal



BALASYS

Proxy tűzfal



BALASYS

Proxy tűzfalak értékelése

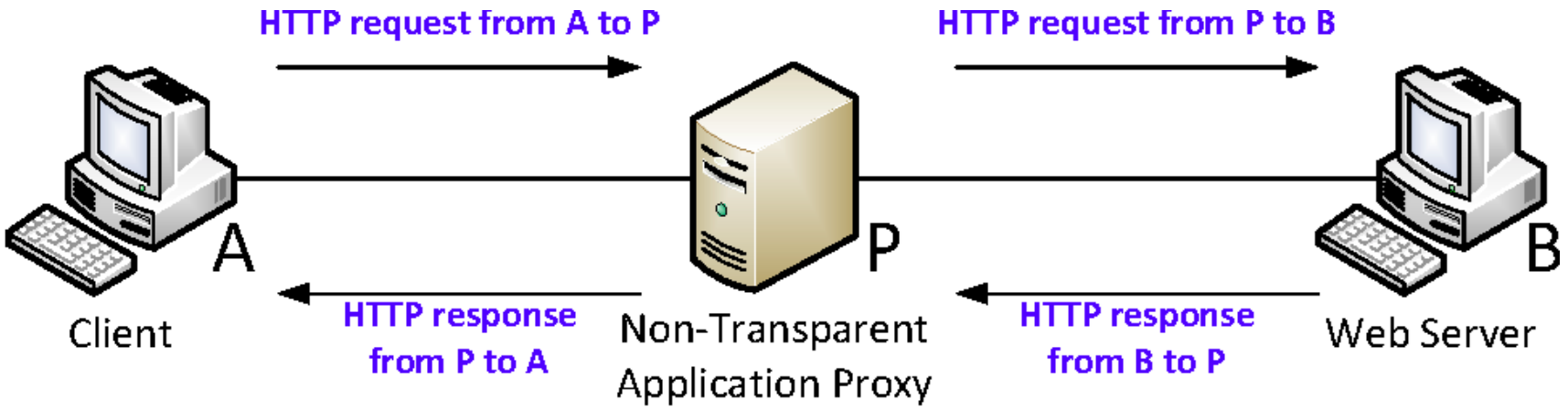
- **Előny**:
  - –Alkalmazás szintű védelem
  - –Protokoll értelmezés, kifinomultabb szűrés
  - –Többcsatornás protokollok elemzése lehetővé válik
- **Hátrány**:
  - –Kliens védelem esetén proxy használatára felkészített kliens szükséges illetve azt támogató protokoll
  - –Lassabb, bonyolultabb a konfigurálás
- **Modern alkalmazása:**
  - –Webserver publikáció
  - –Identity-aware proxy
  - –Load balancing



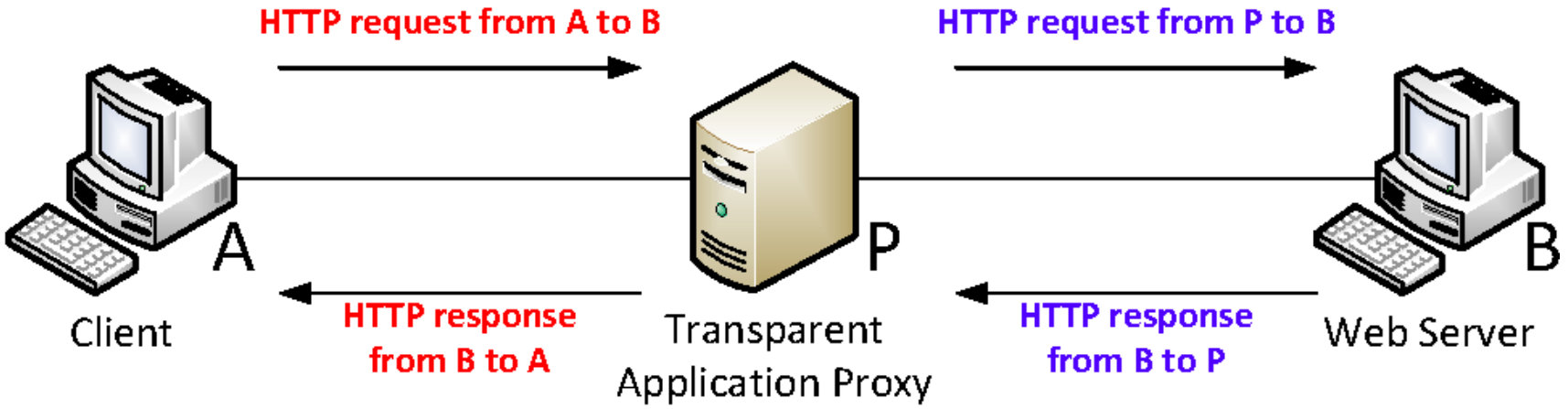
Transzparencia

- **Transzparens működés**: A kliens és a szerver azt hiszi, hogy közvetlenül egymással kommunikálnak.
- **Nem transzparens működés**: A kliens a tűzfallal kommunikál (eltérő protokoll használat lehetséges!).
- **A transzparencia értelmezhető**:
  - Hálózati szinten (TCP/IP)
  - Alkalmazási szinten
  - Kliens vagy szerver oldalon
- Lehet szimmetrikus vagy asszimetrikus
- A hálózati és alkalmazásszintű transzparencia lazán kötődik

Alkalmazásszintű transzparencia



(a) Access network services via a non-transparent proxy.



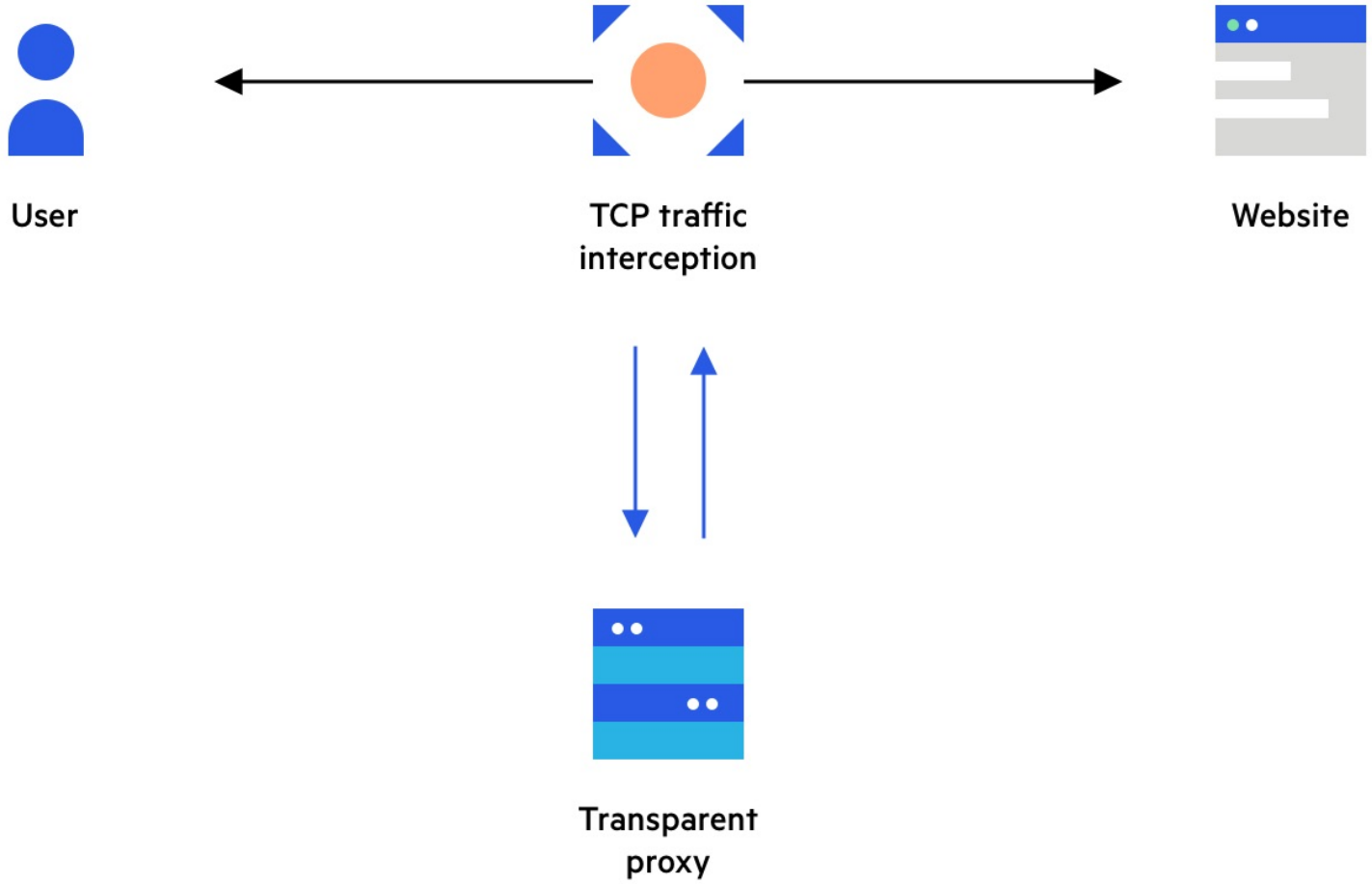
(b) Access network services via a transparent proxy.

BALASYS

Transzparens proxyk

- **Működési elv**: A kapcsolatot valamilyen módon eltérítik eredeti céljától a proxyhoz (Ehhez gyakran csomagszűrőt használnak). A kliens és a szerver számára a kommunikáció transzparens.
- **Döntés alapja**: A kliens és a protokoll minden eleme alkalmazás szinten és az azt hordozó többi réteg (TCP/IP)
- **Megvalósítás**: Összetett. Mintaillesztés a hálózati rétegekben valamint mintaillesztés és **értelmezés** az alkalmazási rétegben. Az értelmezés mélysége függ a megvalósítástól.

Transzparens proxy

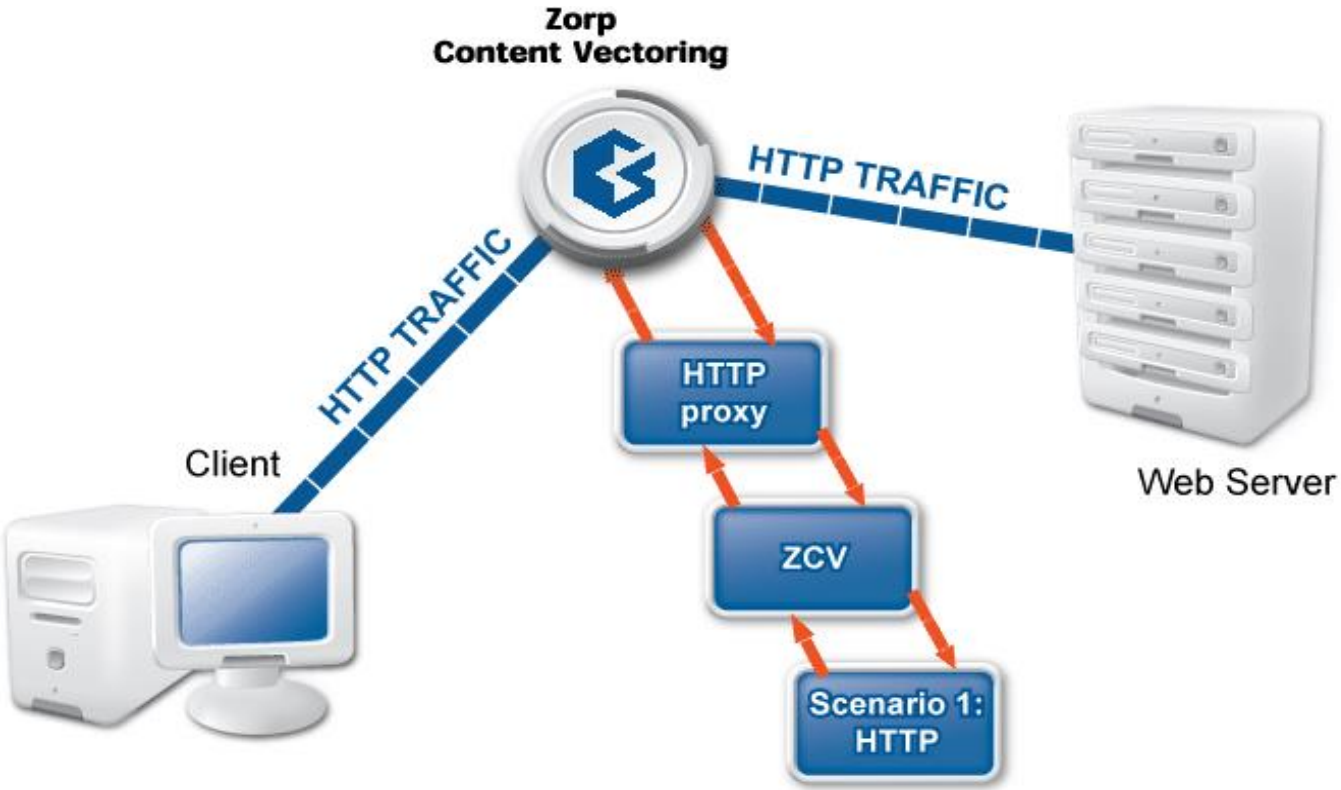


BALASYS

Moduláris proxyk

- **Működési elv**: A feladatokat modulokra osztják és a modulokat kapcsolják egymáshoz. Funkcionalitásban egyezik a transzparens proxykkal.
- **Döntés alapja**: A transzparens proxykkal egyező
- **Megvalósítás**: A transzparens proxykkal egyező

Moduláris proxyk



BALASYS

Moduláris proxyk értékelése

- **Előnyök:**

–Összetett és többcsatornás protokollok elemzése lehetővé válik

–Nagyobb rugalmasság, stabilitás (KISS elv), mélyebb elemzés, skálázhatóság

- **Hátrány:**

–Nagyobb CPU igény

- **Modern alkalmazása:**

–TLS inspection megvalósítása (CheckPoint, Fortigate, Cisco ASA)

–Full protokollértelmezés (Zorp)

Címfordítás

- Az a technológia, mely az eszközön (router vagy tűzfal) áthaladó csomagok forrás vagy cél címét megváltoztatja (NAT: Network Address Translation)
- Fajtái:
  - Egy-egy NAT
  - Sok-egy NAT
  - Forrás és cél NAT (SNAT vagy DNAT)
  - PAT (Port Address Translation)

További határvédelmi funkcionalitások

- Autentikáció
- nIDS és IPS funkcionalitás
- Tartalomszűrés
- Naplózás
- VPN végződtetés (terminálás)

Autentikáció tűzfalakon

- Célja a felhasználó identitásának pontos meghatározása, majd felhasználói jogok hozzárendelése.
- **Protokollon belüli (inband)**: egyes protokollok (pl. ftp és http) támogatják a kliens autentikációját a proxyn, tűzfalon.
- **Protokollon kívüli (outband)**: valamilyen külső eszközzel, független csatornán azonosítjuk a klienst (így a protokoll nem befolyásolja az autentikációs mechanizmust).

nIDS és IPS funkcionalitás tűzfalakon

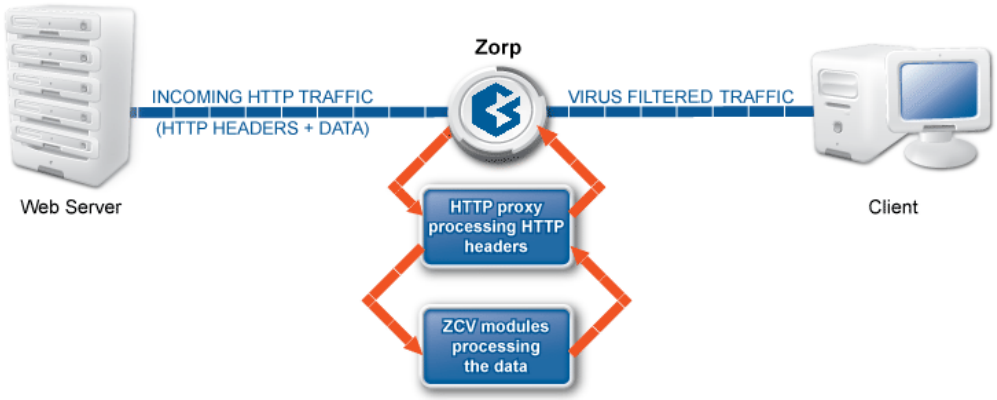
- **Működési elv**: az eszközön áthaladó, engedélyezett forgalomban rossz szándékú aktivitás érzékelése és blokkolása
- Csomagszűrők esetében ez csak kiegészítő eszközzel (modullal) megvalósítható
- Proxyk esetében, amennyiben az ismeretlen protokollelemeket az tiltja, több IPS funkcionalitás megvalósítható

Tartalomszűrés

- Vírusszűrés
- Spam szűrés
- Egyéb tartalom szűrés

–URL

–HTML, XML, SOAP (XML validáció)



BALASYS

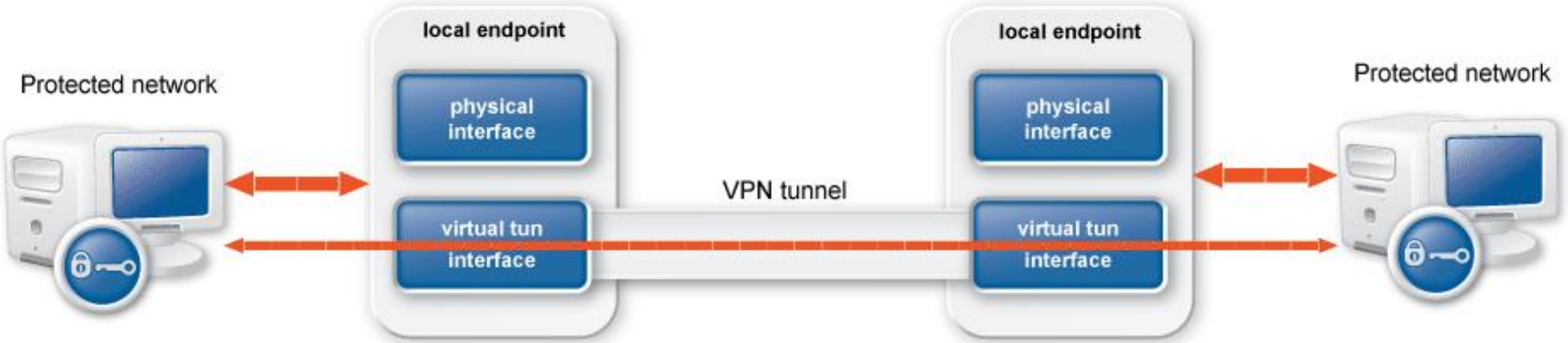
Naplózás

- Minden tűzfal megoldás az által értelmezett protokoll elemekkel kapcsolatos naplózási funkciókat képes megvalósítani.
- Csomagszűrők csak TCP/IP szinten naplóznak
- Proxyk esetében ez akár a teljes kapcsolat és minden protokoll elem naplózását is jelentheti (erőforrás igényes).
- Accounting információk naplózása lehetséges.

Virtuális Magánhálózatok

- Olyan technológiák összessége, mely egymástól távol eső eszközöket és hálózatokat kötnek össze úgy, hogy a köztük megvalósult kommunikáció bizalmassága, sértetlensége és hitelessége ne sérüljön.
- Megvalósítás: általában valamilyen autentikált, rejtjelezett csatornát használnak.
- Alkalmazás szinten: OpenVPN, SSTP, IP over HTTPS és gyártó-specifikus implementációk
- Transzport szinten: IPSec, Teredo, 6to4

Virtuális Magánhálózatok



BALASYS

VPN megvalósítás tűzfalon

- A kikényszerített házirend a VPN csatornákon is érvényes.
- Rejtjelezett kapcsolatokban is lehetséges protokoll ellenőrzés, vírus és tartalom szűrés (melynek feltételeit az IBSZ-ben rögzíteni kell).
- VPN-ek autentikációja a központi PKI rendszerhez.

Integrált határvédelmi megoldások

- Unified Threat Management
- User-based Firewall

BALASYS

Unified Threat Management

- Packet filter + mintaillesztés
- Alkalmazás felismerés signature database segítségével
- Alap TLS inspection
- URL szűrés
- Tartalom szűrés
- Authentikáció
- VPN

- Leánykori nevén Next-generation Firewall

BALASYS

UTM értékelése

- Előnyök:
  - Több technológiát egyesít
  - Egy felületről állítható
  - Nagy rugalmasság
- Hátrány:
  - SPF (Single point of failure)
  - Állandó frissítés
  - „checkbox security” - a pontos működése az adminisztrátor számára nem ismert
- Ismeretlen elemek kezelése:
  - Megvalósítás és szignatúra függő

User-based Firewall

- Packet filter + beépített authentikáció
- User felismerés több forrásból
- Szabályok a felismert felhasználó alapján lépnek érvényre

User-based Firewall értékelése

- Előnyök:
  - IBSZ-ben megfogalmazott szabályokhoz közeli a konkrét tűzfal konfiguráció
- Hátrány:
  - Nem kiforrott user felismerés (agent nélkül)
  - Rugalmatlan szabályrendszer konfiguráció
- Ismeretlen elemek kezelése:
  - Eldobásra kerülnek

Speciális határvédelmi megoldások

- Threat Intelligence
- Software-defined Networking
- Zero Trust Architecture
- Speciális kiegészítő megoldások
  - Web Application Firewall
  - XML firewall
  - API Firewall
  - Dinamikus malware elemzés
  - Terheléselosztók
  - Privileged access monitoring
  - User behaviour analytics

Threat Intelligence

- A hálózaton található biztonsági eszközök együttműködnek és információforrásként szolgálnak egymás számára
- A detektív kontrollok által felismert fenyegetésekre preventív kontrollt léptet életbe

- Példa:
- Végponti víruskereső által felismert fertőzés alapján a határvédelmi eszköz lezárja a hoszt hozzáféréseit

BALASYS

Threat Intelligence értékelése

- Előnyök:
  - Kiegészítő megoldásként nagyban növeli akár egy csomagszűrő hatékonyságát
- Hátrány:
  - Bonyolult infrastruktúra
  - Gyártó specifikus megvalósítások (változóban, STIX/TAXXI)
- Ismeretlen elemek kezelése:
  - Eldobásra kerülnek

Software-defined Networking

- Hálózati eszközök konfigurációját teljesen új alapokra helyezi, központosított, pluginelhető, teljesen rugalmas architektúra kialakításával
- A hálózati döntések elszeparálása négy, jól elkülöníthető rétegre (síkra): menedzsment, szolgáltatás, vezérlés és továbbítás
- Vezérlés (kontroller) és továbbítás (switchek, routerek tűzfalak) valósítja meg a határvédelemet és hálózat szegmentálást
- A továbbítási réteg minden kapcsolatra döntést kér a vezérlési rétegtől
- A vezérlés akár alkalmazást is kérdezhet a döntéshez

Software-defined Networking értékelése

•Előnyök:

–Dinamikus (pl felhő) infrastruktúrák könnyű kezelése

–Emberi hiba kiküszöbölése nagy hálózatokban

–Bevált elemekből építkezik (VLAN, GRE, stb)

•Hátrány:

–A kontroller Single Point of Failure a hálózaton

–A kontroller biztonsága határozza meg minden eszköz biztonsági szintjét

–Az első csomag latency-je nem determinisztikus

–Nehéz hibakeresés, komplex generált konfiguráció

–Önmagában nem hálózatbiztonsági technológia

–Nem kiforrott

BALASYS

Zero Trust Architecture

- A hálózati határt (perimeter) nemlétezőnek tekintjük és az összes eszközt és felhasználót úgy kezeljük, mintha potenciális támadó volna, minden értékünket úgy védjük, mintha az interneten lenne
- Senkiben nincs implicit bizalom, hiába van a „belső hálózaton”
- Oka:
  - Felhő szolgáltatások (O365, Google Suite)
  - Távmunka (COVID-19)
  - Advanced Persistent Threat – célzott támadások számának drasztikus növekedése
  - Lateral movement attack – felhasználói eszközök a támadási ugrópontok

Zero Trust Architecture elemei (NIST)

•Policy Engine (PE):

–A biztonsági házirendet tároló és az alapján döntéseket hozó komponens

–A házirend definiálja a döntéshez az inputokat (pl azonosítási adatbázis), a védendő erőforrásokat és a döntési algoritmust

•Policy Administrator (PA):

–A felhasználó és az erőforrás közötti kommunikációs útvonal engedélyezése vagy tiltása, a PE döntésének végrehajtára

•Policy Enforcement Point (PEP):

–Hálózati határponti preventív kontroll eszköz, ami a PA döntései alapján kezeli az egyes hálózati kapcsolatokat

Zero Trust Architecture módszerek

- Mikroszegmentáció
- Azonosítás
- Threat Intelligence
- Titkosítás
- Láthatóság és analitika
  - forgalmi adatok elemzése (Security Operations Center)
- Automatizáció és orchestration
  - a változások kezelése jól meghatározott folyamatok mentén történik
- Governance
  - ismeri és kezeli a hálózaton megjelenő eszközöket és

BALASYS

Zero Trust Architecture értékelése

•Előnyök:

–Mindent átfogó, paranoid védelmi hozzáállás (nem termék)

–Dinamikusan változó hálózatok, felhasználók és eszközök könnyű kezelése

–Meglévő, bevált best-practice-eket foglalja egységes rendszerbe

•Hátrány:

–A PE/PA Single Point of Failure a hálózaton

–A PE/PA biztonsága határozza meg minden eszköz biztonsági szintjét

–Bevezetése hosszadalmas és nehézkes, mert koncepcióváltást kíván

Speciális kiegészítő megoldások

- Web Application Firewall
  - elterjedt webes sebezhetőségek elhárítása (OWASP Top10)
  - szignatúra alapú
  - széles körben használt alkalmazások hibáira külön ruleset
- XML Firewall
  - biztosítja az XML üzenetek megfelelőségét
  - parzolás és séma validálás, XML signature ellenőrzés
- API Firewall
  - biztosítja az API (SOAP és REST) request és response megfelelőségét

BALASYS

Speciális kiegészítő megoldások

- Dinamikus malware elemzés
  - 0-day és ismeretlen malware-ek felismerése
  - minták futtatása sandboxban és a footprint elemzése
  - viselkedés alapú

- Terheléselosztók
  - szerepük egyre növekszik és változtik
  - alkalmazás szintű tűzfal funkciókat kezdenek megvalósítani
  - scriptelhető

BALASYS

Speciális kiegészítő megoldások

•Privileged access monitoring

–privilegizált felhasználók hozzáféréseinek rögzítése

–munkamenetek 4-szem elv alapú authorizálása

–másodlagos azonosítás hozzáadása a munkamenethez

•User behaviour analytics

–felhasználói viselkedés anomáliáinak felismerése

–machine learning alapú megoldás, baseline építés után automatikus felismerés

–semi-biometrikus adatok (gépelési dinamika, egérmozgás) drámaian növelik a megbízhatóságát

Hálózatbiztonság a felhőben

•Szolgáltatófüggő megoldások

–általában állapottartó csomagszűrő (security groups)

–Identity-aware proxy

–minden cloud szolgáltatónál más feature set ÉS túl sok eszköz, nem egyértelmű céllal

•Kihívások

–a cloud szolgáltatón belüli forgalom integritása, sértetlensége és hitelessége nem biztosított

–orchestration megoldások nem foglalkoznak a biztonsággal

–bonyolult hálózati architektúra nehezíti a kockázatok

BME AUT

Hálózatbiztonság a felhőben

•On-premise virtualizációs infrastruktúra

–VMware Virtual Distributed Switch – ACL-ek (proprietary)

–OpenStack Nova – FwaaS (csomagszűrő), CNI (tunneling)

•Konténer orchestration

–Kubernetes – Ingress Controller (csomagszűrő, proxy és alkalmazásszintű proxy), CNI (tunneling)

•Serverless :D

Kérdések?

Kovács Bálint
Chief Technology Officer
kovacs.balint@balasys.hu

BALASYS

Miről volt szó?

- A hálózati határvédelem értelmezése
- Hálózati alapfogalmak
- Tűzfal típusok
- Határvédelmi technológiák
- Speciális határvédelmi megoldások
- Kérdések és válaszok